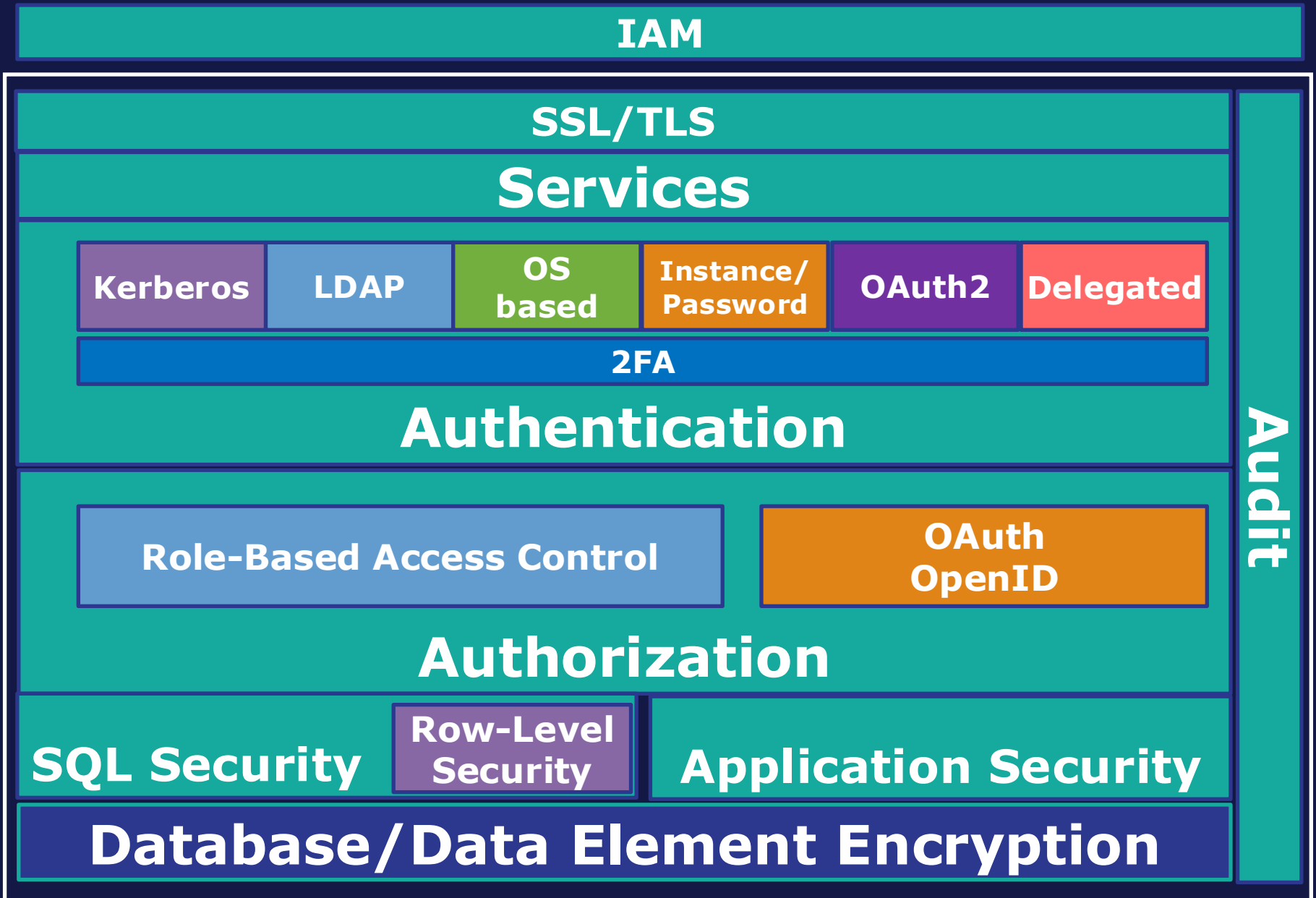


Security Overview





TLS Support

- Can secure various connections to or from instance using TLS.
 - SuperServer connections.
 - Mirroring, xDBC and Java bindings.
 - TCP connections.
- Refer to *Security Administration Guide > TLS Support* for details.



Security Configuration

The logo consists of two vertical bars of different heights, one teal and one white, positioned to the left of the company name.

InterSystems
Creative data technology

Overview

- Security Configuration.
- System-wide Security settings.



Security Configuration

- Security settings kept in database, not iris.cpf file.
 - IRISSECURITY. (v2025.2+)
 - Restricts access.
 - Allows encryption.
- System provides %SecurityAdministrator role for basic security tasks. (v2025.2+)



IRISSECURITY Database

■ Security settings - ^SECURITY

Server irisa Namespace ^^/iris-shared/durable/mgr/irissecurity/ User SuperUser Licensed To Sales Engineers Instance IRIS

System > Globals > View Global Data

View global in database /iris-shared/durable/mgr/irissecurity/:

Global Search Mask: ^SECURITY() Display Cancel

Search History: ^SECURITY() Maximum Rows: 10000 ☐ Allow Edit

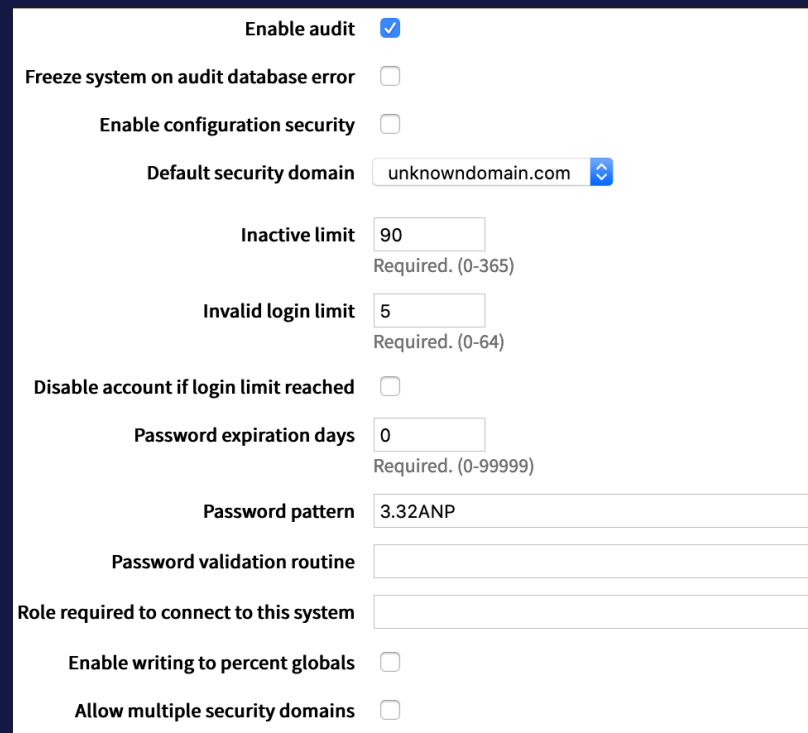
1:	^SECURITY("ApplicationsD")	= "~pointer"
2:	^SECURITY("CSP")	= "~pointer"
3:	^SECURITY("EventsD")	= "~pointer"
4:	^SECURITY("LDAPConfigsD")	= "~pointer"
5:	^SECURITY("PhoneProvidersD")	= "~pointer"
6:	^SECURITY("ResourcesD")	= "~pointer"
7:	^SECURITY("RolesC")	= "~pointer"
8:	^SECURITY("RolesD")	= "~pointer"
9:	^SECURITY("SQL")	= "~pointer"
10:	^SECURITY("SSLConfigsD")	= "~pointer"
11:	^SECURITY("SecuritySettings")	= "Normal"
12:	^SECURITY("ServersD")	= "~pointer"
13:	^SECURITY("ServicesD")	= "~pointer"
14:	^SECURITY("SystemD")	= "~pointer"
15:	^SECURITY("UsersD")	= "~pointer"
16:	^SECURITY("Version")	= 2026.1
17:	^SECURITY("WebAppPctAccessD")	= "~pointer"

Total: 17 [End of global]



System-wide Security Settings

- May need to change default settings.
 - System Administration > Security > System Security > System-wide Security Parameters.
 - Can also update using `%SYS>do ^SECURITY.`



The screenshot shows a configuration window for system-wide security parameters. It includes several settings with checkboxes and input fields, some with required ranges.

Setting	Value	Notes
Enable audit	☒	
Freeze system on audit database error	☐	
Enable configuration security	☐	
Default security domain	unknowndomain.com	Dropdown menu
Inactive limit	90	Required. (0-365)
Invalid login limit	5	Required. (0-64)
Disable account if login limit reached	☐	
Password expiration days	0	Required. (0-99999)
Password pattern	3.32ANP	
Password validation routine		
Role required to connect to this system		
Enable writing to percent globals	☐	
Allow multiple security domains	☐	



Login Accounts

- Invalid login limit.
 - # of unsuccessful attempts allowed before:
 - Escalating time delay imposed on each successive attempt.
- Disable account if invalid login limit reached.
 - Used with Invalid login limit.
 - Instead of imposing delay, disables account when limit reached.

Inactive limit	90
	Required. (0-365)
Invalid login limit	5
	Required. (0-64)
Disable account if login limit reached	☐
Password expiration days	0
	Required. (0-99999)



Login Accounts (cont.)

- Inactive limit.
 - # of days between successful logins before user account marked disabled.
- Password Expiration Days.
 - # of days before passwords expire.
 - Applies to all accounts, including those used by system itself.
 - Value of 0 indicates passwords never expire.

Inactive limit	90
	Required. (0-365)
Invalid login limit	5
	Required. (0-64)
Disable account if login limit reached	☐
Password expiration days	0
	Required. (0-99999)



Password Pattern

- Rule pattern must be compatible with ObjectScript pattern matching operator.
 - X.Y[ANP]
 - X is minimum # or characters.
 - Y is maximum # of characters.
 - ANP specifies if Alphabetic, Numeric and Punctuation characters allowed.
 - 3.128ANP
 - 3–128 characters in length.
 - Letters, numbers and punctuation characters allowed.

Password pattern

3.128ANP



Password Validation

- Password validation routine.
 - User-provided routine for validating passwords.
 - For example, checking if password previously used by user.
 - Refer to PasswordValidationRoutine method in Security.System class for more information.
 - Used in addition to checking specified Password pattern.
- Role required to connect to system.
 - User must be member of specified role in order to log into system.

Password validation routine

Role required to connect to this system



Default Security Settings

Security Setting	Minimal	Normal	Locked Down
_SYSTEM user is enabled	Yes	Yes	No
User authentication required	No	Yes	Yes
Password pattern default *	3.128ANP	3.128ANP	8.128ANP
Role assigned to UnknownUser	%All	<None>	<None>
Create install username and password	No	Yes	Yes

* x.128ANP indicates x-128 characters in length, including letters, numbers and punctuation characters allowed.



Initial Password Settings

- Normal and Locked Down installations:
 - Specify one default password for all predefined users during install.
- Minimal installation:
 - Default password for all predefined users is "SYS".



Suggested Readings

- *System Management and Security.*
- *Security > Securing Your Instance > Preparing for InterSystems Security.*



Auditing



Overview

- Auditing basics.
- Auditing events.
- Demonstration.
- Auditing management.



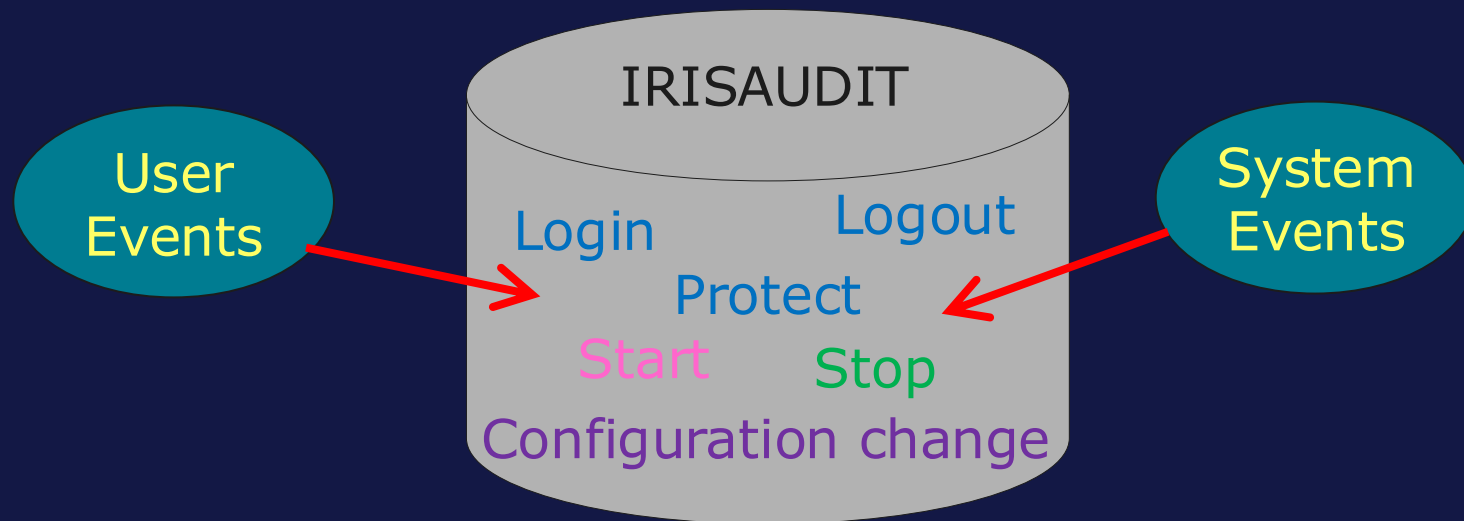
Audit Trail

- Record showing who has accessed system and what operations they have performed during given period of time.



Auditing

- Logs certain key events in secure audit database.
 - System events.
 - Custom user events.



Auditing Basics

- Select events to audit.
- Enable auditing.
- System automatically creates entry in database when events occurs.
- Review audit entries as needed.

Time «	Event Source	Event Type	Event	PID	Web Session	User	Description	
2020-04-02 18:51:07.148	%System	%Security	AuditReport	917	nVADq8mbC5	SuperUser	List Query	Details
2020-04-02 18:51:02.337	%System	%Security	AuditChange	917	nVADq8mbC5	SuperUser	Modify Event %System/%SQL/XDBCStatement	Details
2020-04-02 18:50:59.586	%System	%Security	AuditChange	917	nVADq8mbC5	SuperUser	Modify Event %System/%Login/Logout	Details
2020-04-02 18:50:58.810	%System	%Security	AuditChange	917	nVADq8mbC5	SuperUser	Modify Event %System/%Login/Login	Details
2020-04-02 18:50:57.067	%System	%Security	AuditChange	917	nVADq8mbC5	SuperUser	Modify Event %System/%DirectMode/DirectMode	Details
2020-04-02 18:50:48.878	%System	%Login	LoginFailure	917	nVADq8mbC5	SuperUser	/csp/sys login failure	Details
2020-04-02 18:50:17.533	%System	%Security	AuditReport	917	nVADq8mbC5	SuperUser	List Query	Details
2020-04-02 18:50:12.933	%System	%Security	AuditReport	917	nVADq8mbC5	SuperUser	List Query	Details
2020-04-02 18:49:47.979	%System	%Security	AuditReport	911	nVADq8mbC5	SuperUser	List Query	Details
2020-04-02 00:06:01.621	%System	%Security	AuditChange	14908		_SYSTEM	Delete audit data	Details



Audit Database

- IRISAUDIT.
- Standard database.
- Must be journaled.
- Can be encrypted.
- New entries added to end of log.



System Events

- Enable or disable as needed.

Event Name »	Enabled
%Ensemble/%Message/ViewContents	Yes
%Ensemble/%Production/ModifyConfiguration	Yes
%Ensemble/%Production/StartStop	Yes
%Ensemble/%Schema/Modify	Yes
%System/%DirectMode/DirectMode	No
%System/%Login/Login	No
%System/%Login/LoginFailure	Yes
%System/%Login/Logout	No
%System/%Login/Terminate	No
%System/%Security/ApplicationChange	Yes
%System/%Security/AuditChange	Yes
%System/%Security/AuditReport	Yes
%System/%Security/DBEncChange	Yes
%System/%Security/DocDBChange	Yes

Event Name »	Enabled
%System/%SQL/DynamicStatement	No
%System/%SQL/EmbeddedStatement	No
%System/%SQL/XDBCStatement	No
%System/%System/AuditRecordLost	Yes
%System/%System/ConfigurationChange	Yes
%System/%System/DatabaseChange	Yes
%System/%System/JournalChange	Yes
%System/%System/OSCommand	Yes
%System/%System/RoutineChange	No
%System/%System/Start	Yes
%System/%System/Stop	Yes
%System/%System/SuspendResume	No
%System/%System/UserEventOverflow	Yes

Event Name »	Enabled
%System/%Security/DomainChange	Yes
%System/%Security/LDAPConfigChange	Yes
%System/%Security/Protect	No
%System/%Security/ResourceChange	Yes
%System/%Security/RoleChange	Yes
%System/%Security/ServiceChange	Yes
%System/%Security/SSLConfigChange	Yes
%System/%Security/SystemChange	Yes
%System/%Security/UserChange	Yes
%System/%SMPEXplorer/Change	No
%System/%SMPEXplorer/ExecuteQuery	No
%System/%SMPEXplorer/Export	No
%System/%SMPEXplorer/Import	No
%System/%SMPEXplorer/ViewContents	No



System SQL Events (v2024.3+)

- Provides granular control for SQL statements.
 - SQL origin: Dynamic SQL, embedded SQL, or ODBC/JDBC.
 - Type of statement: SELECT, DDL, DML, or utility.

Event Name	Enabled
%System/%SQL/DynamicStatementDDL	No
%System/%SQL/DynamicStatementDML	No
%System/%SQL/DynamicStatementQuery	No
%System/%SQL/DynamicStatementUtility	No
%System/%SQL/EmbeddedStatementDDL	No
%System/%SQL/EmbeddedStatementDML	No
%System/%SQL/EmbeddedStatementQuery	No
%System/%SQL/EmbeddedStatementUtility	No
%System/%SQL/PrivilegeFailure	No
%System/%SQL/XDBCStatementDDL	No
%System/%SQL/XDBCStatementDML	No
%System/%SQL/XDBCStatementQuery	No
%System/%SQL/XDBCStatementUtility	No



Custom User Events

- User-defined application events.
 - Can use to track events happening within application.
- Configure in Management Portal.
- Logged only if programmed into application.
 - Add audit entry by calling `$SYSTEM.Security.Audit()` in application code.

Event Name	Enabled	Total	Written			
MyAppSource/MyAppType/MyAppName	Yes	0	0	Reset	Change Status	Delete



Demo

- Enable auditing.
- Create and view audit entries.
- Create user event to audit.
- System Administration > Security > Auditing.

Enable Auditing	
Disable Auditing	
View Audit Database	
Configure System Events	
Configure User Events	
Copy Audit Log	
Export Audit Log	
Purge Audit Log	



Audit Event Properties

Uniquely
identifies
type of
event

Audit Details:	
Description	Modify Event %System/%Login/Login
Timestamp	2020-04-02 18:50:58.810
UTCTimestamp	2020-04-02 18:50:58.810
Event Source	%System
Event Type	%Security
Event	AuditChange
Username	SuperUser
Pid	917
JobId	196628
JobNumber	20
IP Address	172.17.0.1
Executable	CSPap.so
System ID	3e3a15aa11c4:IRIS
Index	387
Roles	%All
Authentication	Password
Namespace	%SYS
Routine	
User Info	
O/S Username	CSP Gateway
Status	
Event Data	Modify Event: %System/%Login/Login Enabled modified: New value: Yes Old value: No ----- Current values: Description: Audit successful login events Enabled: Yes



User Event Overflow

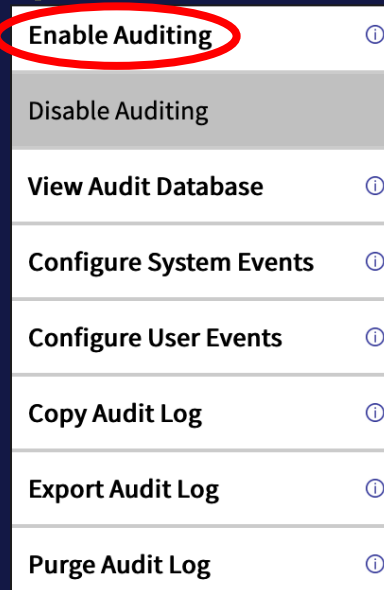
- If event occurs which is not predefined, it is written into audit log as:
 - Event = "UserEventOverflow".
 - Description = "Added unknown audit event".

Event Source	Event Type	Event	PID	Web Session	User	Description
%System	%Security	AuditReport	911	nVADq8mbC5	SuperUser	List Query
%System	%System	UserEventOverflow	21148		irisowner	Added unknown audit event
%System	%Security	AuditReport	911	nVADq8mbC5	SuperUser	List Query



How To: Enable Auditing

- System Administration > Security > Auditing > Enable Auditing.
- %SYS>do ^SECURITY
 - Auditing Setup.
 - Enable auditing.
- Auditing disabled by default for Minimal security installations.



How To: Enable Events

- System Administration > Security > Auditing > Configure System/User Events.
- %SYS>do ^SECURITY
 - Auditing Setup.
 - Configure auditing.

Enable Auditing	
Disable Auditing	①
View Audit Database	①
Configure System Events	①
Configure User Events	①
Copy Audit Log	①
Export Audit Log	①
Purge Audit Log	①



How To: View Audit Entries

- System Administration
> Security > Auditing
> View Audit Database.

- Can query based on multiple criteria.

- %SYS>do ^SECURITY

- Auditing Setup.
- View system audit database.

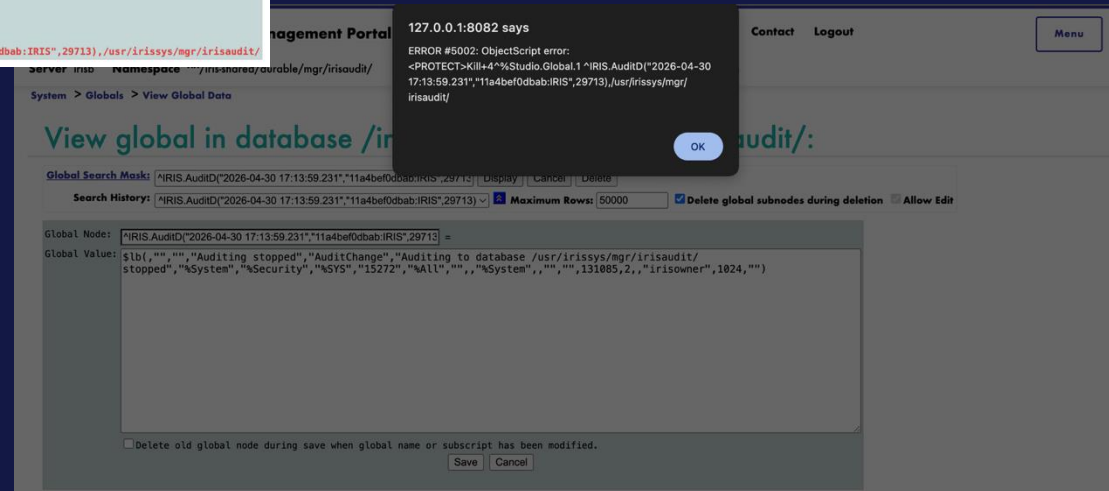
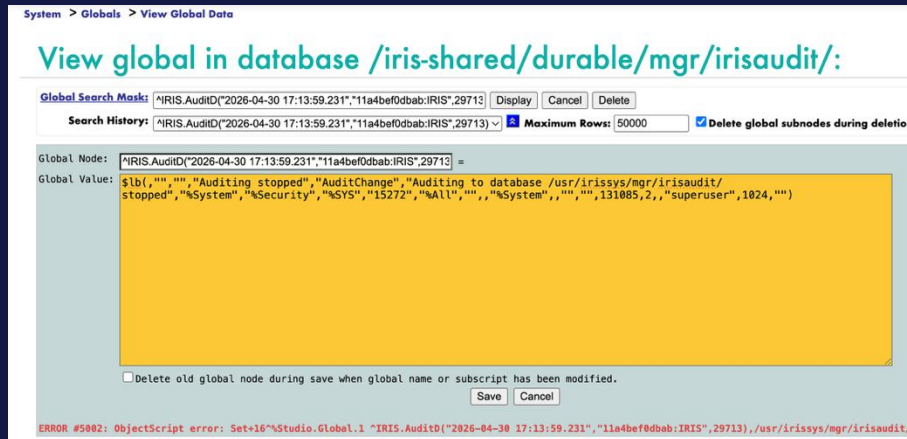
- %SYS>do ^%AUDIT

View Audit Database				
Event Source				
Event Type				
Event Name				
System IDs				
PIDs				
Users				
* (All)				
Admin				
CSPSystem				
IAM				
irisowner				
srose				
Authentications				
* (All)				
Kerberos Credentials Cache				
Kerberos				
Kerberos				
Operating System				
Password				
Begin Date/Time				
End Date/Time				
Maximum Rows				
1000				
Reset Values				
Search				
Page size: 1000 Results: 407 Page: 1 of 1				
Time	Event Source	Event Type	Event	
2020-04-02 18:59:05.251	%System	%Security	AuditChange	
2020-04-02 18:59:05.250	%System	%Security	SystemChan	
2020-04-02 18:57:35.839	%System	%Security	AuditReport	
2020-04-02 18:57:34.592	%System	%System	UserEventOv	
2020-04-02 18:57:25.418	%System	%Security	AuditReport	
2020-04-02 18:57:21.544	%System	%Security	AuditReport	
2020-04-02 18:57:16.812	%System	%Security	AuditReport	
2020-04-02 18:57:14.313	%System	%Login	Login	
2020-04-02 18:57:09.656	%System	%Login	Logout	
2020-04-02 18:57:04.063	%System	%Security	AuditChange	
2020-04-02 18:56:43.104	%System	%Login	Login	
2020-04-02 18:56:43.079	%System	%Security	AuditReport	
2020-04-02 18:56:41.489	%System	%System	UserEventOv	
2020-04-02 18:56:41.484	%System	%DirectMode	DirectMode	
2020-04-02 18:54:29.372	%System	%Security	AuditReport	
2020-04-02 18:53:32.800	%System	%Security	AuditReport	
2020-04-02 18:53:21.530	%System	%Security	AuditChange	
2020-04-02 18:51:07.148	%System	%Security	AuditReport	
2020-04-02 18:51:02.337	%System	%Security	AuditChange	
2020-04-02 18:50:59.586	%System	%Security	AuditChange	
2020-04-02 18:50:58.810	%System	%Security	AuditChange	
2020-04-02 18:50:57.067	%System	%Security	AuditChange	
2020-04-02 18:50:48.878	%System	%Login	LoginFailure	



Audit Log Tamper Resistance

- Users cannot tamper with audit logs



Managing Audit Database

- System Administration
> Security > Auditing.
- %SYS>do ^SECURITY
 - Auditing Setup.
 - Manage audit logs.
- %SYS>do ^%AUDIT
- Options:
 - Copy entries to another namespace.
 - Export entries to file.
 - Purge entries based on # of days.

Enable Auditing	
Disable Auditing	i
View Audit Database	i
Configure System Events	i
Configure User Events	i
Copy Audit Log	i
Export Audit Log	i
Purge Audit Log	i



Automatic Purging

- By default, Task Manager task runs after midnight.
- Purges entries older than 62 days.
- Can edit task as needed.

Task Name	Task Type	Namespace	Description
Switch Journal	System	%SYS	Switches the journal file at midnight every day
Purge Journal	System	%SYS	Purges old journal files every night at 12:30 am
Purge Tasks	System	%SYS	Purges the task history global every night at 1:00 am
Integrity Check	System	%SYS	Integrity check for databases at 2:00 am every Monday
Security Scan	System	%SYS	Scans the security database at midnight every day
Diagnostic Report	System	%SYS	Send system diagnostic reports to WRC On Demand, and/or on a schedule
Purge Audit Database	System	%SYS	Purges old Audit information after Switch Journal is run
Inventory Scan	System	%SYS	Run a scan of the system inventory on install or upgrade and on demand
Purge errors and log files	System	%SYS	Purges errors and log files at 1:00 am
Check Logging activity	System	%SYS	Check active application logging at 1:00 am
Purge Backup Log	System	%SYS	Purges old messages from IRIS backup log every night at 1:30 am



Audit Database Error

- By default, system generates error if cannot write to audit database.
 - Writes error to Messages Log.
 - System continues running without audit entries.
 - When problem resolved, audit entry AuditRecordLost written to indicate # of audit entries lost.



Audit Database Error (cont.)

- Option exists to freeze system on audit database error.
 - System Administration > Security > System Security > System-wide Security Parameters > Freeze system on audit database error.
 - %SYS>do ^SECURITY
 - Auditing Setup.
 - Enable Auditing.
 - Freeze system on audit database error.
 - Enter Yes.
 - Writes error message to Messages Log.



Suggested Readings

- *Auditing Guide.*



Summary

- What are the key points for this module?



Services



Overview

- Service basics.
- Demonstration.
- Specific services.
- Securing services.



Service

- Controls connecting to system using InterSystems connection technologies.
 - **Cannot** create own services.



Service

Name	Enabled	Public	Authentication Methods	Allowed Connections	Description
%Service_Bindings	Yes	N/A	Password	Unrestricted	Controls SQL or Objects
%Service_CacheDirect	No	Yes	Password	Unrestricted	Controls Cache Direct
%Service_CallIn	No	Yes	Password	Unrestricted	Controls the Call-In Interface
%Service_DataCheck	No	N/A		Unrestricted	Controls this system as a DataCheck source
%Service_DocDB	No	No		Unrestricted	Controls Doc DB applications
%Service_ECP	Yes	N/A		Unrestricted	Controls Enterprise Cache Protocol (ECP)
%Service_Login	Yes	No	Password	Unrestricted	Controls SYSTEM.Security.Login
%Service_Mirror	No	N/A		Unrestricted	Controls Mirroring
%Service_Monitor	No	N/A		Unrestricted	Controls SNMP and remote Monitor commands
%Service_Shadow	No	N/A		Unrestricted	Controls if this system can be the source of a shadow
%Service_Sharding	No	N/A		Unrestricted	Controls this system as a Shard Server
%Service_Terminal	Yes	Yes	Password	Unrestricted	Controls terminal session on Unix
%Service_WebGateway	Yes	Yes	Password	Unrestricted	Controls Web Gateway access
%Service_Weblink	No	N/A	Unauthenticated	Unrestricted	Controls Weblink



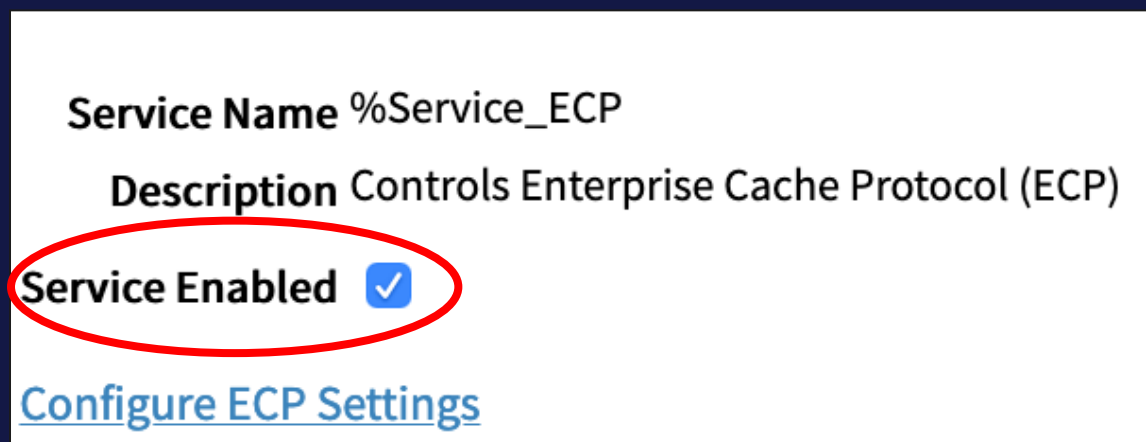
Initial Services Settings

Service	Minimal	Normal	Locked Down
%Service_Bindings	Enabled	Enabled	Disabled
%Service_CacheDirect	Enabled	Disabled	Disabled
%Service_CallIn	Enabled	Disabled	Disabled
%Service_ComPort	Disabled	Disabled	Disabled
%Service_Console (Windows Only)	Enabled	Enabled	Enabled
%Service_DataCheck	Disabled	Disabled	Disabled
%Service_ECP	Disabled	Disabled	Disabled
%Service_Login	Enabled	Enabled	Enabled
%Service_Mirror	Disabled	Disabled	Disabled
%Service_Monitor	Disabled	Disabled	Disabled
%Service_Terminal (Unix® and Linux Only)	Enabled	Enabled	Enabled
%Service_WebGateway	Enabled	Enabled	Enabled



Enabling/Disabling Services

- Disabling/enabling not just security setting.
- Determines:
 - If corresponding system process starts.
 - Allocation of memory structures.
- System Administration > Security > Services.



Console and Terminal Services

- %Service_Console:
 - Service only on Windows installations.
 - Will not appear as service on UNIX® and Linux installations.
- %Service_Terminal:
 - Service only on UNIX® and Linux installations.
 - Will not appear as service on Windows installations.



Gateway Service

- Access to web applications controlled by %Service_WebGateway.
 - disabling the **%Service_WebGateway** service does not prevent users from accessing **built-in applications**
- Changes may impact availability of Management Portal.
 - If locked out, can make changes using:
 - %SYS>do ^SECURITY, if command line available.
 - Emergency access mode.



Client System Security

- List of IPs or machine names that may connect using service.
 - Optional.
- Available for many services.

Allowed Incoming Connections

Index	IP Address	Roles
1	TESTSVR	Edit Delete
2	10.1.0.19	Edit Delete

[Add New](#) [Delete All](#)



Service Connection Summary

- Connecting via service allowed for user if:
 - Service enabled.
 - For basic service with client system security in use:
 - Machine IP or name in list of allowed connections.
 - User authenticates for service's specified authentication mechanism.
 - User has appropriate permissions to access asset, such as database.



Controlling Service Connections

- Options for restricting connections using particular service:
 - Choose particular authentication mechanism.
 - Only those who can authenticate via that mechanism can use service.
 - Do not allow Unauthenticated.
 - Disable service.
 - No one can use service.
 - Recommended if service not used.



Hands-on

- Follow exercise 1
 - Disable/Enable Service %Service_Terminal



Authentication



Overview

- Definition.
- Authentication options.
- Delegated authentication.
- Two-factor authentication.



Authentication Definition

- Process of determining whether someone or something is, in fact, who or what it is declared to be.
 - Check identity is valid.



Authentication Options

- InterSystems Instance Authentication.
 - InterSystems username/password account.
 - In Portal, called Password Authentication.
- OS-based Authentication.
 - OS username must match user definition in instance.
 - Instance does not prompt user for username.
- Unauthenticated.
 - Appropriate if organization has strongly protected perimeter, or data/application not attractive target.



External Authentication Options

- LDAP.
 - System retrieves information from LDAP repository of user information.
- OAuth2 (v2025.2+).
 - OpenID Connect authentication specific to using IRIS as client or server for OAuth2 authorization.
- Kerberos.
 - Secure authentication method over unsecured network.
- Delegated.
 - User-defined authentication.



Allowing Authentication Options

- System Administration > Security > System Security > Authentication/Web Session Options.

Allow Unauthenticated access	☒
Allow O/S authentication	☒
Allow O/S authentication with Delegated authorization	☐
Allow O/S authentication with LDAP authorization	☐
Allow Password authentication	☒
Allow Delegated authentication	☐
Always try Delegated authentication	☐
Allow Kerberos authentication	☐
Allow LDAP authentication	☒
Allow LDAP cache credentials authentication	☐
Allow OAuth2 authentication	☐
Allow creation of Login Cookies	☐
Login Cookie expire time (secs)	0 0 implies non-persistent cookie
Allow Two-factor Time-based One-time Password authentication	☐
Allow Two-factor SMS text authentication	☐



Authentication and Services

- Below shows some services and valid authentication methods.

Service Name	KRB Cache	KRB Login	Del	LDAP	OS	IA	Un
%Service_Bindings	N	Y	Y	Y	N	Y	Y
%Service_CallIn	N	N	Y	Y	Y	N	Y
%Service_ComPort	N	N	Y	Y	N	Y	Y
%Service_Console	Y	Y	Y	Y	Y	Y	Y
%Service_Login	N	N	Y	Y	Y	Y	Y
%Service_Telnet	N	Y	Y	Y	N	Y	Y
%Service_Terminal	Y	Y	Y	Y	Y	Y	Y
%Service_WebGateway	N	Y	Y	Y	N	Y	Y



InterSystems Instance Authentication

- User definition stored in IRIS.
- Uses table of hashes to store passwords.
- Default password criteria:
 - 3.128ANP (Minimal and Normal).
 - 8.128ANP (Locked Down).
- System Administration > Security > System Security Settings > System-wide Security Parameters.

Password pattern

3.128ANP

A = Alphabetic(A–Z, a–z) N = Numeric(0–9) P = Punctuation



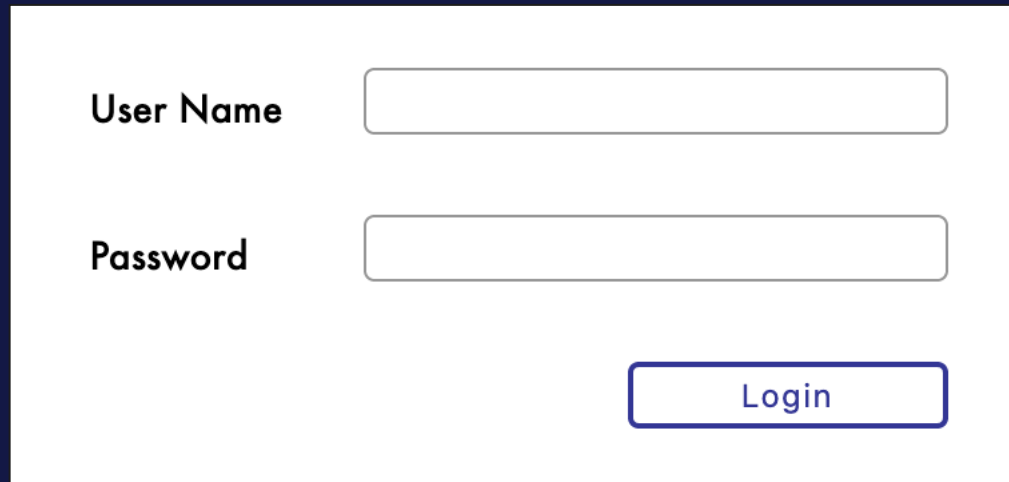
OS-Based Authentication

- Available with connection services of:
 - Terminal (Local connections on UNIX® and Linux).
 - Console (Local connections on Windows).
- Available only for local processes.
 - CallIn (All platforms).



Unauthenticated Access

- User tries to log in with no username/password:
 - If Unauthenticated is enabled:
 - User connects through Unauthenticated.
 - If Unauthenticated not enabled:
 - User denied access.



A login form with a white background and rounded corners. It contains two input fields: 'User Name' and 'Password', each with a light blue border. Below the 'Password' field is a 'Login' button with a blue border and the text 'Login' in blue. The labels 'User Name' and 'Password' are in a bold, black font.



Authentication Notes

- `write $USERNAME` provides current username.
 - Any background process (started with Job command) inherits username of process that created it.
- `do $SYSTEM.Security.Login()` allows application to change user it is logged in as.
- Use audit log to troubleshoot “Access Denied” messages.
 - Audit entry provides details about access failure.



Configuring Delegated Authentication

- Create ZAUTHENTICATE routine with user-defined code.
- Enable Delegated authentication for system.
- Enable Delegated authentication for relevant services.



Delegated Authentication Process

- User supplies username and password to system.
- Username and password validated using ZAUTHENTICATE.
 - If passes:
 - User created or modified in system.
 - Any code setting roles or other characteristics used.



Authentication and User Types

- User can only have one type.
- User of one type cannot log in using mechanism associated with another type.

User Type	Authentication Used
Password user	InterSystems login, Kerberos, OS-based. All without delegated authorization.
LDAP user	LDAP.
Delegated user	Delegated.
OS user	OS-based authentication with delegated authorization.
Kerberos user	Kerberos authentication with delegated authorization.

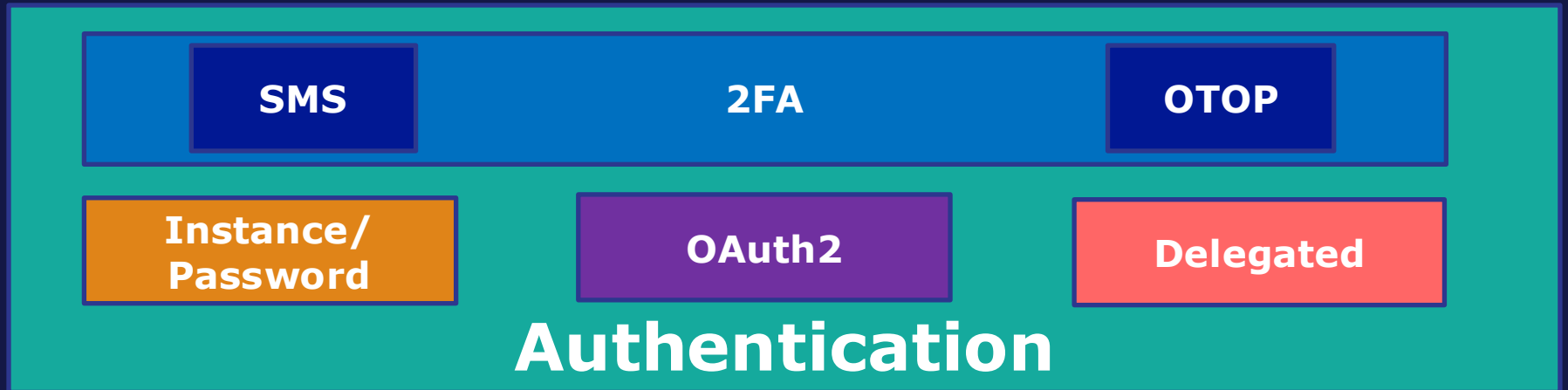


Hands-on

- Follow exercise 2, test authentication methods using terminal connections.
 - Unauthenticated.
 - InterSystems Instance (Password) Authentication.
 - OS-based.



Two-Factor Authentication (2FA)



Two-factor Time-based One-time Password (TOTP)

- Uses time-based one-time password algorithm to generate token on smartphone or other device.
 - User does not need network connection.
 - Secret key must be shared between server and user's device ahead of time over secure channel.
- System prompts for token after authentication.
 - Server uses same algorithm to verify token.



How To: Set up TOTP

- Enable TOTP system-wide.
 - System Administration > Security > System Security > Authentication Options > Allow Two-factor Time-based One-time Password authentication.
- Enable TOTP for particular services.
 - System Administration > Security > Services > Select Service > Check Two-factor Time-based One-time Password.



How To: Set up TOTP (cont.)

- Enable TOTP for each user.
 - System Administration > Security > Users.
 - Provide key or QR code to user through secure channel.

Two-factor Authentication

Time-based One-time Password enabled ☒

Display Time-Based One-time Password QR Code on next login ☐ (Not Recommended)

[Generate a new Time-based One-time Password Key](#)

Issuer IRIS-USVMSSCHAFER-IRIS611

Account Anne

Base 32 Time-based One-time Password (OTP) Key 5IBM ZAGP 4CZ6 EKMN UOP6 6GNU
RVLH RXM4



How To: Set up TOTP (cont.)

- User adds key to smartphone or device.
 - New token based upon timestamp generated every 30 seconds.
- For more details on TOTP algorithm tools.ietf.org/html/rfc6238.



Hands-On TOTP

- Follow exercise 3



Suggested Readings

- *Authentication Guide.*
 - *Delegated Authentication.*
- *LDAP Guide.*
- *Authorization Guide.*
 - *Using Delegated Authorization.*



Authorization: Basics



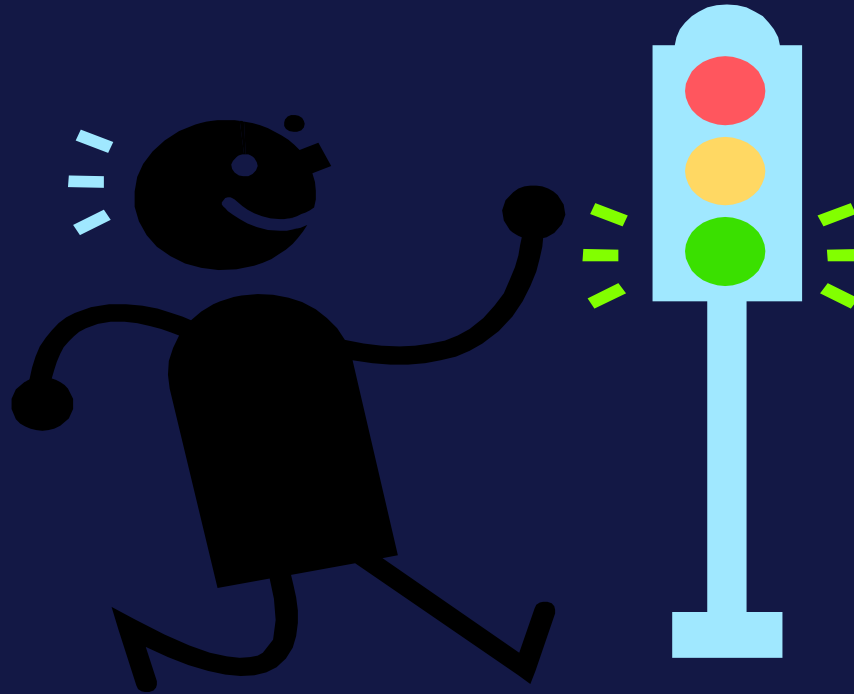
Overview

- Users.
- Roles.
- Privileges.
- Resources.
- Assets.



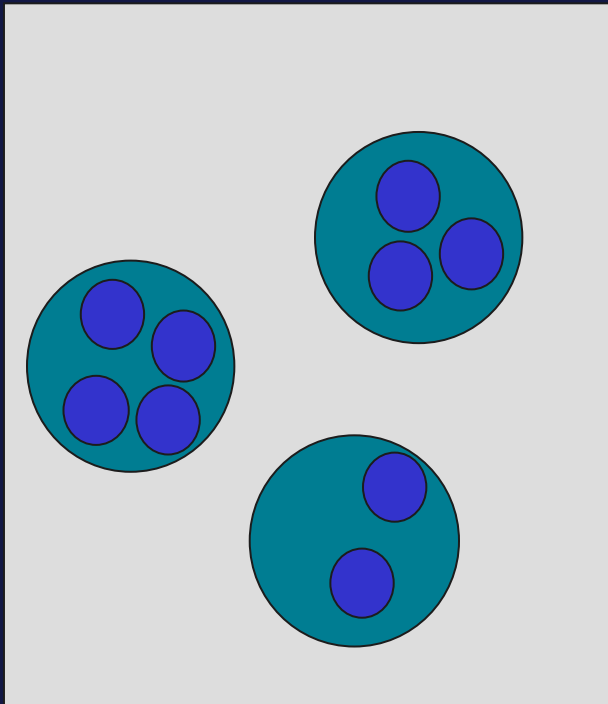
Authorization Definition

- Process of giving someone permission to do or have something.



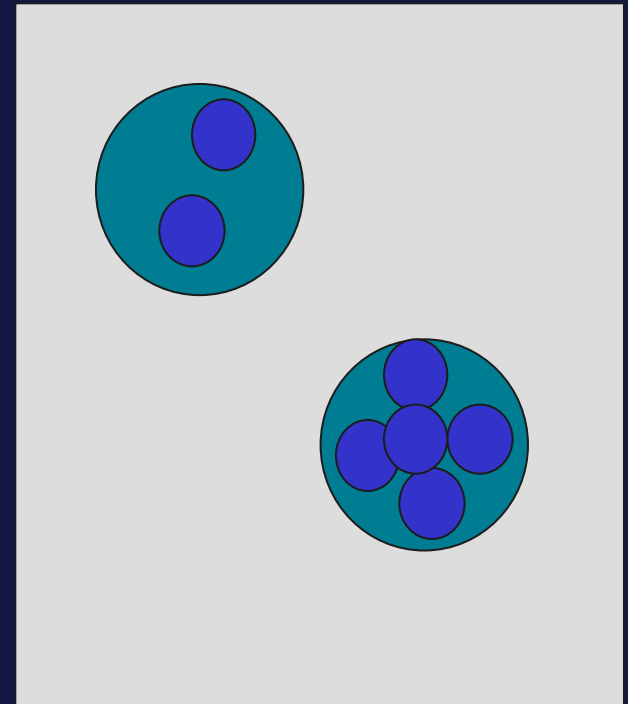
Authorization Basics

User A



User ■
Role ○
Privilege ●

User B



Users

- Define one user for each person accessing system.

Filter:

Page size:

Max rows:

Results: 10

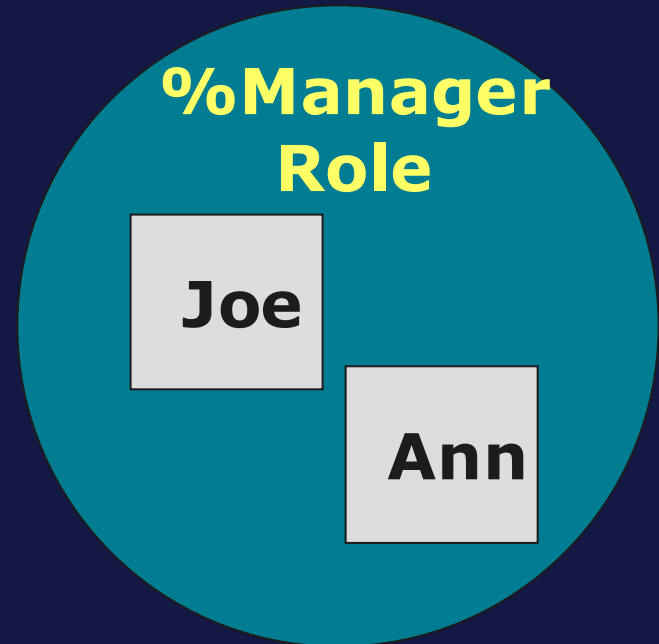
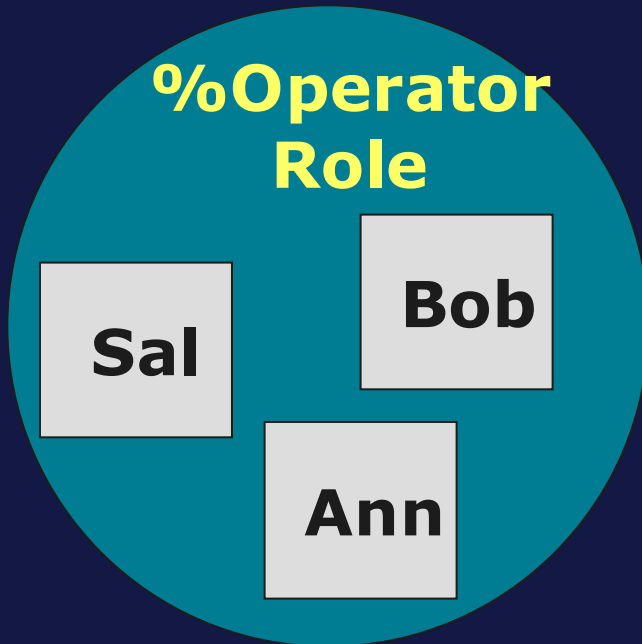
Page: of 1

	Name	Full Name	Enabled	Namespace	Routine	Type		
	Admin	System Administrator	Yes			Password user	Delete	Profile
	CSPSystem	Web Gateway user	Yes			Password user	Delete	Profile
	IAM	User for /api/iam Web Application	No			Password user	Delete	Profile
	irisowner	User who installed system	Yes			Password user	Delete	Profile
	srose		Yes			Password user	Delete	Profile
	SuperUser	System Super user	Yes			Password user	Delete	Profile
	UnknownUser	Unauthenticated user	Yes			Password user	-	Profile
	_Ensemble	Interoperability Manager (Internal use - not for login)	Yes			Password user	Delete	Profile
	_PUBLIC	(Internal use - not for login)	No			Password user	-	Profile
	_SYSTEM	SQL System Manager	Yes			Password user	-	Profile



Roles

- Roles can have multiple members.
- Users can be members of multiple roles.



Privileges

- Roles are named collections of privileges.
- Privileges provide permissions on resources.
 - Possible permissions: Read, Write or Use.
 - Executing code requires Read permission for database.
 - Possible resources: databases, services and others.
- For example, some privileges of %Operator role on InterSystems IRIS:

Resource	Permission
%DB_IRISTEMP	Read, Write
%DB_IRISLOCALDATA	Read
%Service_WebGateway	Use



Privileges

**Privilege =
Resource:Permission**

- Example Privileges:
 - %DB_IRISTEMP:RW
 - %DB_IRISLIB:R
 - %Admin_Operate:U
 - %Service_WebGateway:U



Demonstration

- Look at resources.

Resources

[Create New Resource](#)[Export](#)[Import](#)[Delete](#)[Profile](#)

Public Permissions

☒ Read

☒ Write

☒ Use

☒ No permissions

Resource Name

Maximum rows

« InterSystems IRIS resources provide access for users based on the rights they hold. The following resources are currently available:

Page size: 0 Results: 107 Page: < << 1 >> > of 1

☐	Name	Description	Public Permission	Resource Type		
☐	%Admin_Journal	Enables setting or clearing the no journaling process flag in programmer mode		System	Edit	Delete
☐	%Admin_Manage	For System Managers: Grants access to system management utilities		System	Edit	Delete
☐	%Admin_Operate	For System Operators: Grants access to operator utilities		System	Edit	Delete
☐	%Admin_Secure	For Security Administrators: Grants access to security utilities		System	Edit	Delete
☐	%Admin_Task	For Task Manager Administrators: Grants access to Task Manager utilities		System	Edit	Delete
☐	%DB_%DEFAULT	Resource for databases that are not otherwise known to the system		Database	Edit	-
☐	%DB_ENSLIB	The ENSLIB database	R	Database	Edit	Delete
☐	%DB_IRISAUDIT	The AUDIT database		Database	Edit	Delete
☐	%DB_IRISLIB	The System Library database	R	Database	Edit	Delete
☐	%DB_IRISLOCALDATA	The IRISLOCALDATA database	R	Database	Edit	Delete
☐	%DB_IRISSYS	The System database		Database	Edit	Delete
☐	%DB_IRISTEMP	The TEMP database	RW	Database	Edit	Delete



Resources

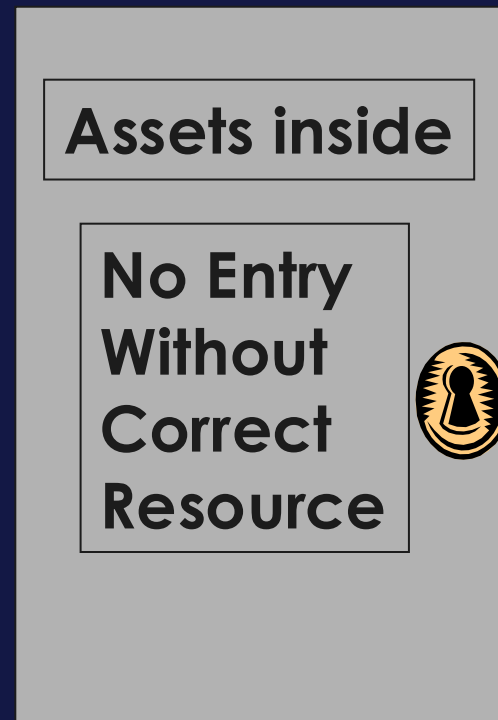
- After user has authenticated, resources control whether assets are accessible to user.
 - Resource with proper permissions are required to access assets.



Resource A



Resource B



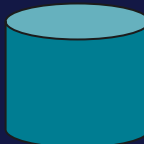
Assets

- Something that is protected.
- Examples include:
 - Databases.
 - Services.
 - Applications.
 - System management functions.



Assets and Resources

- Below are sample relationships between assets and resources.
 - One resource could be used to protect multiple assets.

Resource	Asset(s) Protected	Relationship
 %DB_IRISSYS	 IRISSYS	One-to-one
 %Admin_Manage	 Many system management functions	One-to-many



Public Resource

Edit Definition for Resource %DB_USER

Resource Name

%DB_USER

Required. Enter 1-64 characters.

Description

The USER database

Public Permission

☒ Read ☐ Write

- Any resource can be designated as public.
- Equivalent to all users holding privilege for resource.



Predefined Users

Username	Roles	Purpose
SuperUser	%All	Account with all privileges available.
_SYSTEM	%All	Account to support SQL access.
Admin	%Manager	Admin account.
UnknownUser	%All – Minimal None – Normal, Locked Down	Account for unidentified user.
CSPSystem	None	Login for Web Gateway for Normal and Locked Down installations; internal use.
_Ensemble	%All	Interoperability user for InterSystems IRIS; internal use.
_PUBLIC	None	Set of privileges given to all users (not a login account); internal use.



Predefined Users (cont.)

- Recommend disabling most predefined users.
 - `_SYSTEM`, `SuperUser`, `Admin`, `UnknownUser`.
 - Users should not log in using generic accounts.
- Can delete unwanted predefined users.
 - Cannot remove `_SYSTEM`, `_PUBLIC` or `UnknownUser`.
 - At least one user must have `%All` role.
 - Does not matter which user has `%All`.
 - System will not allow deletion of last user with `%All` role.



Predefined Users (cont.)

- SuperUser
 - Exists to help with initial security configuration.
 - Disable/remove after initial set up is complete.
- _SYSTEM
 - Supports standard SQL specification.
 - Is disabled in a Locked Down installation
- _PUBLIC
 - Not for login. Used to assign roles to all users after user connects to system.
 - Add roles as desired.



UnknownUser

- Used when unauthenticated user connects to system.
 - Service must allow unauthenticated access.
 - Not used when authentication fails!
- UnknownUser has privileges from:
 - Roles of UnknownUser.
 - Roles of _PUBLIC.
 - Public resources.
- In minimal install, all users connect as UnknownUser (has %All role).

Allowed Authentication Methods

☒ Unauthenticated

☒ Password

☐ Kerberos

User Name

Password



Default User Passwords

- Change existing default passwords.
 - `_PUBLIC` and `UnknownUser` have no password.

Installation Type	Default Password
Locked Down	Defined during installation
Normal	Defined during installation
Minimal	SYS



How To: Create Users

- **System Administration > Security > Users > Create New User.**

The screenshot shows the 'Create New User' form with the following fields and options:

- General** (tab 1)
- Roles** (tab 2)
- EscalationRoles** (tab 3)
- SQL Admin Privileges** (tab 4)
- SQL Tables** (tab 5)
- SQL Views** (tab 6)

Fields and options in the General tab:

- Name**: AdminAnita (Required.)
- Full Name**: [Text box]
- Comment**: [Text box]
- Password**: ☐ Enter new password ☒ Leave as is
- Change password on next login**: ☐
- Password never expires**: ☐
- User enabled**: ☒
- Account Never Expires**: ☐
- Account expiration Date**: [Text box] (yyyy-mm-dd)
- Startup Namespace**: [Dropdown menu]
- Startup Tag^Routine**: [Text box]
- Email Address**: [Text box]

Red annotations: A red line connects the 'General' tab (1), the 'Roles' tab (2), and the 'EscalationRoles' tab (3).



Examples of Predefined Roles

- %All
- %Developer
- %Manager
- %Operator
- %SQL
- %EnsRole_Operator
- %EnsRole_Developer
- %DB_%DEFAULT
- %DB_USER
- %DB_IRISLIB



Predefined Roles (cont.)

- Cannot delete some predefined roles.
 - For example: %All, %Developer, %Operator, %Manager, %SQL.
- %All
 - Cannot be modified.
 - At least one user account must have %All role.



How To: Create Roles

- Role naming conventions:
 - Must not start with %.
 - Cannot differ from another role name only by case.
- System Administration > Security > Roles > Create New Role.

The screenshot shows the 'Create New Role' dialog box with the following components and annotations:

- General Tab:** The first tab, labeled with a red circle '1'.
- Name:** A text field containing 'TestRole' with a red circle '1' next to it. Below the field is the text 'Required.'.
- Description:** A text field with a red circle '2' next to it.
- Privileges:** A table with two columns: 'Resource' and 'Permission'. It contains two rows of data and an 'Add...' button at the bottom.
- Assigned To Tab:** The second tab, labeled with a red circle '2'.
- SQL Privileges Tab:** The third tab, labeled with a red circle '3'.
- SQL Tables Tab:** The fourth tab.

Resource	Permission		
%DB_IRISSYS	RW	Edit	Delete
%Service_Terminal	U	Edit	Delete

Add...



How To: Create Roles (cont.)

- **System Administration > Security > Roles > Create New Role.**

Edit definition for role TeamMember:

General **Members** Assigned To

Users and Roles Assigned to Role TeamMember:

User or Role Name	Type	
Jack	USER	Remove
Supervisor	ROLE	Remove

[Remove All](#)

Assign additional users or roles by selecting one or more available users or roles and pressing [Assign].

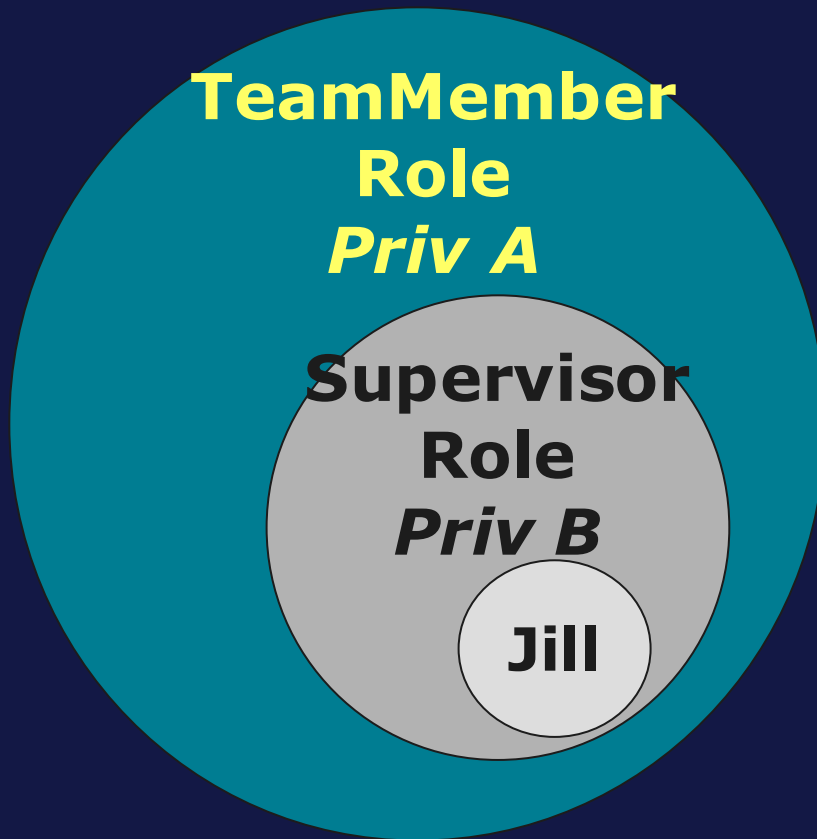
☐ Users ☒ Roles

Possible member types:

- Users
- Roles



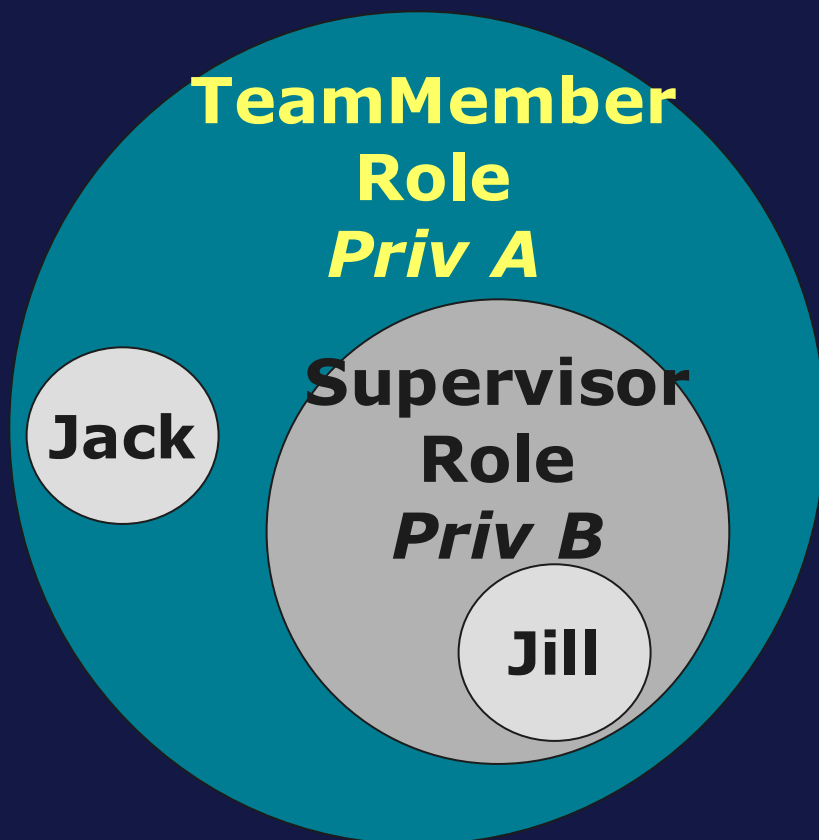
Role as Role Member



- Jill is a Supervisor.
- Supervisor is also TeamMember.
- Jill has Priv A and Priv B.
- Can be used as way to not assign privileges directly to role.
 - Supervisor could be empty role.
 - Jill gets privileges of TeamMember.



Role as Role Member (cont.)



- Jack is a TeamMember.
- Jack has Priv A only.



Role as Role Member (cont.)

User, Jill, holds the following privileges:

Asset		Privileges			Granted by role
Resource	Protects	R	W	U	
%Admin_Manage	System manager tasks Applications: /csp/sys/mgr			U	Supervisor:U
%Admin_Operate	System operator tasks Applications: /csp/sys/op			U	TeamMember:U

Edit definition for role TeamMember:

General Members

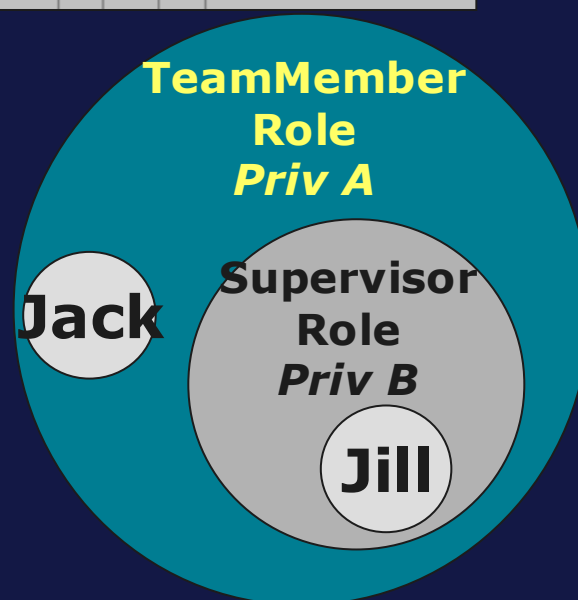
Users and Roles Assigned to Role TeamMember:

User or Role Name	Type
Jack	USER
Supervisor	ROLE

Remove All

Assign additional users or roles by selecting one or more

☐ Users ☒ Roles



Role as Role Member (cont.)

- Example shows assigning Supervisor (more-privileged role) to TeamMember (less-privileged role).
 - Supervisor is also TeamMember.
- In general, assigning less-privileged role to more-privileged role is **not** recommended.
 - TeamMember should **not** also be Supervisor.



Hands-on

- Follow Exercise 4

Users	ⓘ
Roles	ⓘ
Resources	ⓘ
Services	ⓘ
Applications	>
SSL/TLS Configurations	ⓘ
X.509 Credentials	ⓘ
OAuth 2.0	>
Managed File Transfer Connections	ⓘ
System Security	>
Auditing	>
Security Advisor	ⓘ
Mobile Phone	ⓘ
Public Key Infrastructure	ⓘ



Predefined Resources

- Start with %.
- For resource descriptions:
 - Refer to *Security Administration Guide > Assets and Resources*.



Resource Groups

Type	Name	Permission
Administration 	%Admin_<...>	Use
Database 	%DB_<...>	Read, Write
Development 	%Development	Use
Service 	%Service_<...>	Use
System 	%System_CallOut	Use
User-defined 	User-defined	User-defined



How To: Create Resources

- Resource naming conventions:
 - Cannot start with %.
 - Exception: database resources.
 - Cannot differ from another resource name only by case.
- Decide if resource should be public.
- System Administration > Security > Resources > Create New Resource.

Create a New Resource Name

Resource Name

1

Required. Enter 1-64 characters.

Description

2

Public Permission

☒ Read ☐ Write ☐ Use



New %DB_ Resource

- When creating new %DB_resource, role with RW permissions for resource automatically created.

New Database	New Resource	New Role
PATIENTS	%DB_PATIENTS	%DB_ PATIENTS

View system defined role definition **%DB_PATIENTS:**

General Members Assigned To

Name
Required.

Description

Privileges

Resource	Permission		
%DB_PATIENTS	RW	-	-



How To: Associate Resource with DB

- When creating database:
 - Select when using database wizard.
- After database created:
 - System Administration > Configuration > System Configuration > Local Databases > Select database > Select Resource.

The screenshot shows a configuration window for a database named 'FINANCES'. The 'Name' field is 'FINANCES' with a 'Required.' note below it. The 'Directory' is 'C:\InterSystems\databases\finances' with a folder icon. 'Encrypted' is set to 'No'. 'Block Size' is '8192 Bytes'. The 'Size (MB)' section has 'Current' at 325 (with '>=1' below), 'Expansion' at 0 (with '0 for Default' below), and 'Maximum' at 0 (with '0 for Unlimited' below). The 'Resource Name' field is highlighted with a red circle and contains '%DB_FINANCES', with a dropdown arrow and a 'Create New Resource...' button to its right. The 'New Global' section shows 'Collation' as 'IRIS standard' (with a dropdown arrow), 'Growth Block' as 50 (with '>=50' below), and 'Pointer B' partially visible.



Management Portal Security

- All pages in Management Portal protected by %Admin_Manage, %Admin_Operate, %Admin_Secure or %Development.

System Configuration >	Memory and Startup ⓘ	LOCAL DATABASES View or edit local databases. Go Add to favorites System Resource(s) %Admin_Manage Custom Resource - Assign
Connectivity >	Namespaces ⓘ	
Mirror Settings >	Local Databases ⓘ	
Database Backup >	Remote Databases ⓘ	
Web Gateway Management ⓘ	Sharding Configuration ⓘ	
SQL and Object Settings >	Journal Settings ⓘ	
Device Settings >		
National Language Settings >		



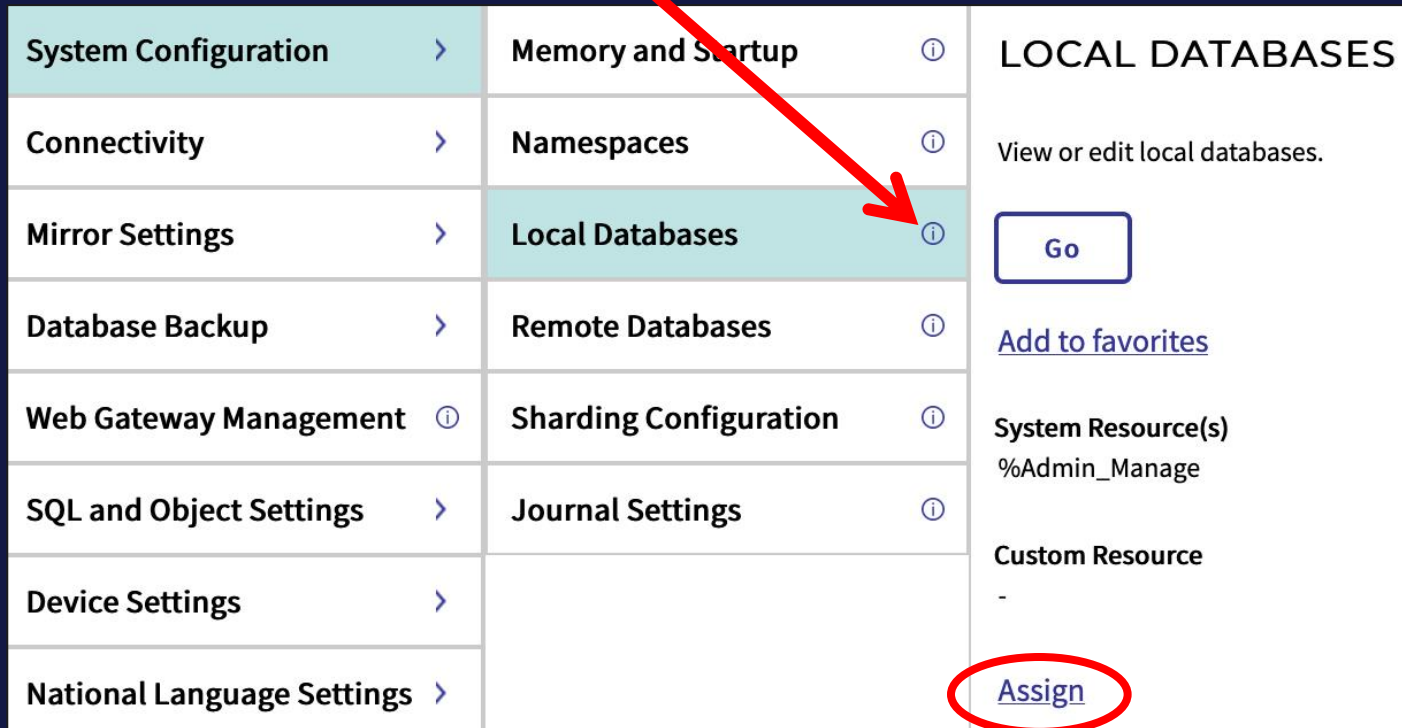
Customizing Management Portal Security

- Can associate custom resources with individual Management Portal pages for finer-grained security.
 - Must have permission on both system and custom resource to access.
- Links in Management Portal display both system and custom resources required.



How To: Customize Management Portal Security

- To associate resource with page:
 - Click in box containing link.
 - Click Assign.



The screenshot shows the Management Portal Security configuration interface. On the left, a sidebar lists various configuration categories. The 'Memory and Startup' section is expanded, showing 'Local Databases' as a link. A red arrow points from this link to the 'Assign' button in the 'LOCAL DATABASES' section on the right. The 'LOCAL DATABASES' section contains a 'Go' button, a link to 'Add to favorites', and a table of system resources.

System Configuration	Memory and Startup	LOCAL DATABASES
Connectivity	Namespaces	View or edit local databases.
Mirror Settings	Local Databases	Go
Database Backup	Remote Databases	Add to favorites
Web Gateway Management	Sharding Configuration	System Resource(s)
SQL and Object Settings	Journal Settings	%Admin_Manage
Device Settings		Custom Resource
National Language Settings		-



How To: Customize Management Portal Security

- Select any custom or predefined resource from list.

ASSIGN CUSTOM RESOURCE

Assign a custom resource to a page within the Portal

This dialog lets you assign an additional custom resource to a page within the Portal. In addition to the system resource assigned to the page, users must have USE privileges for this resource in order to view the page.

Page Name

Local Databases

Page Link

/csp/sys/mgr/%25CSP.UI.Portal.Databases.zen

Page Class

%CSP.UI.Portal.Databases

Custom Resource Name



Resource Profile

- Can see profile view of selected resources.

The screenshot shows the 'Resources' management interface. At the top, there are buttons for 'Create New Resource', 'Export', 'Import', 'Delete', and 'Profile'. The 'Profile' button is circled in red. On the left, there are filters for 'Public Permissions' (Read, Write, Use, No permissions) and a 'Resource Name' search box containing an asterisk. Below these is a 'Maximum rows' dropdown set to 1000. The main content area shows a table of resources with columns 'Name' and 'Description'. The table is on page 1 of 1, with 106 results. The resources listed are:

Name	Description
☐ %Admin_Journal	Enables setting or clearing the no journaling proc
☒ %Admin_Operate	For System Operators: Grants access to operator
☒ %Admin_Secure	For Security Administrators: Grants access to sec
☐ %Admin_Task	For Task Manager Administrators: Grants access
☐ %DB_%DEFAULT	Resource for databases that are not otherwise kn
☐ %DB_ENSLIB	The ENSLIB database
☒ %DB_IRISAUDIT	The AUDIT database
☐ %DB_IRISLIB	The System Library database



Resource Profile (cont.)

- Profile shows:
 - Roles containing resource.
 - Databases protected by resource.
 - Applications protected by resource.
 - Public permissions.

Profile for 3 Resources			
%Admin_Operate	Description: For System Operators: Grants access to operator utilities Type: System Public Permission: (none)		
	Roles	Databases	Applications
	%Manager %Operator		/csp/sys/op
%DB_IRISAUDIT	Description: The AUDIT database Type: Database Public Permission: (none)		
	Roles	Databases	Applications
	%DB_IRISAUDIT %Manager	/usr/irissys/mgr/irisaudit/	
%DB_IRISSYS	Description: The System database Type: Database Public Permission: (none)		
	Roles	Databases	Applications
	%DB_IRISSYS %Manager %Operator	/usr/irissys/mgr/	



Authorization Basics Overview

- User can have permissions from multiple roles.

User has assigned roles.

→ Role has assigned privileges.

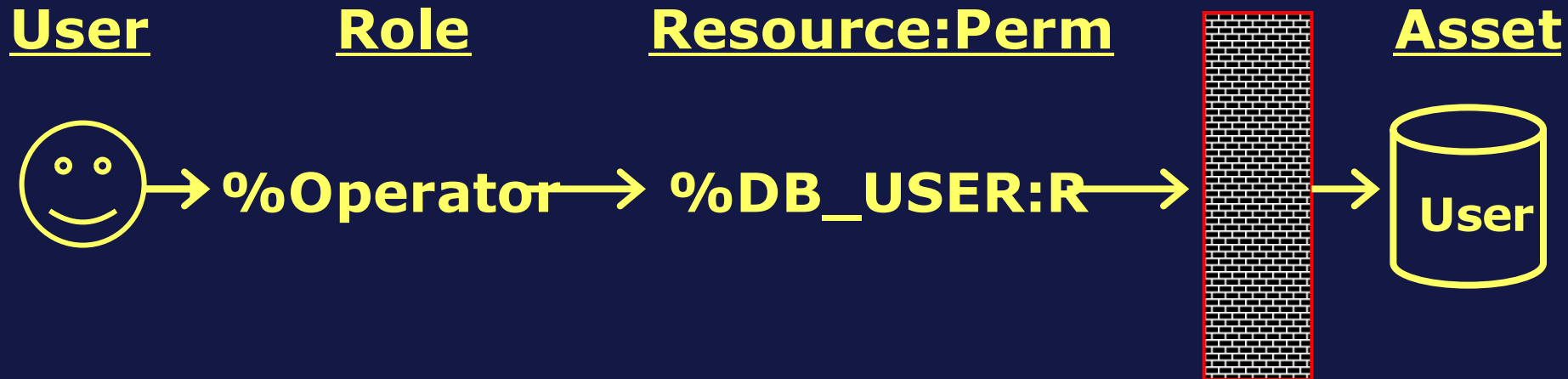
→ Privilege grants permission.

User A	Roles	Privileges	
		Resource	Permission
	%Operator	%DB_IRISTEMP	Read, Write
		%DB_IRISLOCALDATA	Read
		%Service_DocDB	Use
		%Service_WebGateway	Use
		%Admin_Operate	Use
	%DB_USER	%DB_USER	Read, Write
	%SQL	%Service_SQL	Use



Summary Sentence

Users are members of roles granting permissions on resources protecting assets.



Authorization: Service/Resource Relationship



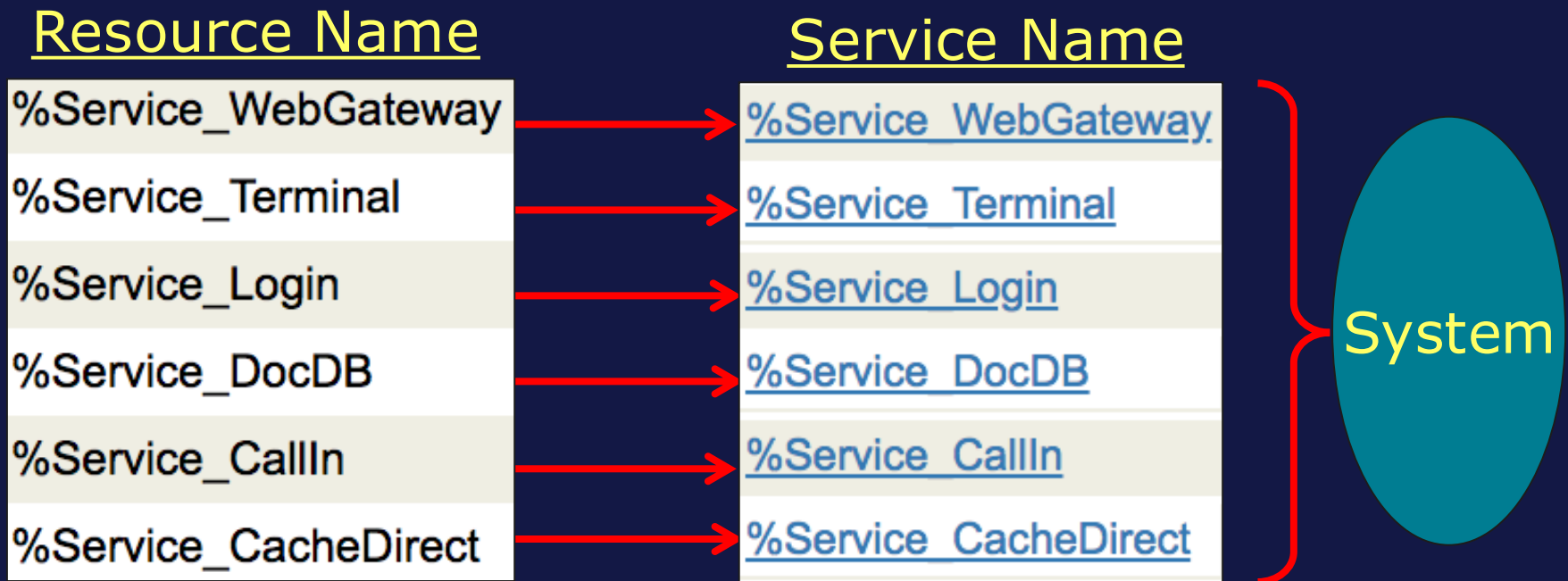
Overview

- Service/Resource Relationship
- Basic vs. Resource-based Services



Service/Resource Relationship

- Service governs access to system.
- Resource governs access to Service.



Basic vs. Resource-based Services

	Basic	Resource-based
Type of connection.	System to system.	User to system.
Has associated resource.	No.	Yes.
Uses authentication and authorization infrastructure.	No.	Yes.
Example.	%Service_ECP	%Service_Console



Public Resource

- Available to all users.
 - Does not require user to have role with corresponding resource privilege.
- If corresponding resource for service is public:
 - Any user can employ service.

Edit Definition for Resource %Service_WebGateway

Resource Name	%Service_WebGateway
	Required. Enter 1-64 characters.
Description	Controls Web Gateway sessions
Public Permission	☒ Use



Services and Resources

Name	Enabled	Public
%Service_Bindings	Yes	N/A
%Service_CacheDirect	No	Yes
%Service_CallIn	Yes	No
%Service_DataCheck	No	N/A

N/A Exception:
Two resources

No resource
required

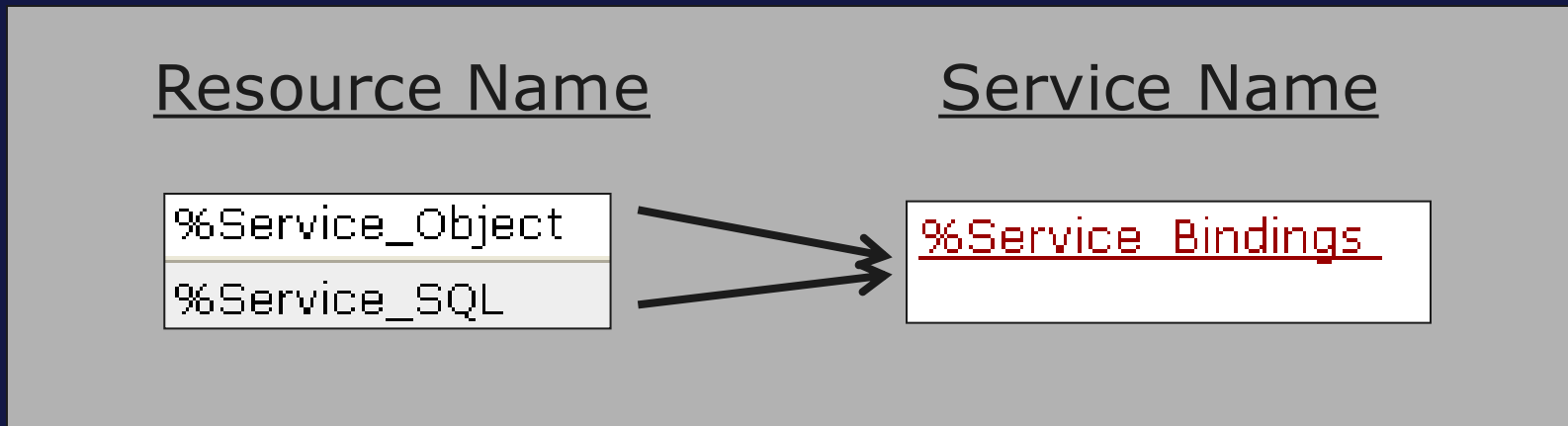
Resource
required

Not
resource-based
service



%Service_Bindings Service

- Using %Service_Bindings controlled by:
 - %Service_Object resource.
 - Controls whether data accessible as objects.
 - %Service_SQL resource.
 - Controls whether data accessible using SQL.
- Must be enabled for Studio access.
 - **Not** used for VS Code.



Use Permission is Not Enough

- Permission for service not enough to accomplish access and data manipulation.
 - Need additional permissions, such as Read on database.
- For example, on Windows, to successfully connect to %SYS namespace and run ^BACKUP, user needs:
 - %Service_Console:Use.
 - %Development:Use.
 - Grants access to command line.
 - %DB_IRISSYS:Read.



Default Routine for User

- Can restrict user to only run certain routine in Terminal session.
 - Does not require %Development:Use.
 - Does require other necessary privileges.

A screenshot of a user configuration form. The form contains the following fields and options:

- Name:** Jack (Required.)
- Full Name:** (Empty text box)
- Comment:** (Empty text box)
- Password:** ☐ Enter new password ☒ Leave as is
- Change password on next login:** ☐
- Password never expires:** ☐
- User enabled:** ☒
- Account Never Expires:** ☐
- Account expiration Date:** (Empty text box) (yyyy-mm-dd)
- Startup Namespace:** %SYS (Dropdown menu, circled in red)
- Startup Tag^Routine:** ^OPER (Text box, circled in red)



Authorization: Applications



Overview

- Application definition basics.
- Role escalation.
- Demonstration.
- Creating application definitions.



Application-based Security

- Protect application from unauthorized use.
- Allow user to have privileges only within control of application.
- Prevent unauthorized role escalation.



Types of Application Definitions

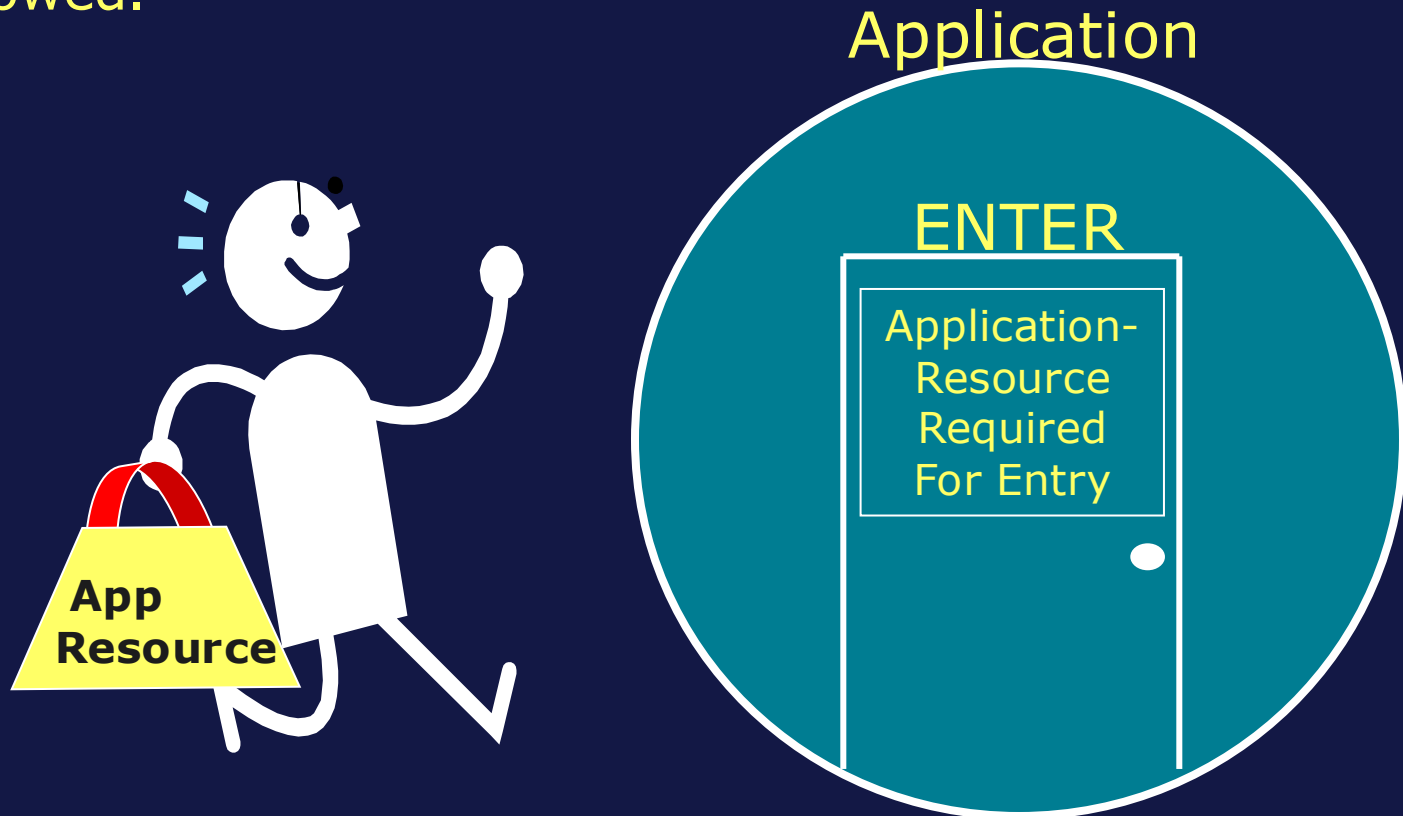
- Application-based security provided via application definitions.
 - System Administration > Security > Applications.

Web Applications	i
Doc DB Applications	i
Privileged Routine Applications	i



Common Capabilities

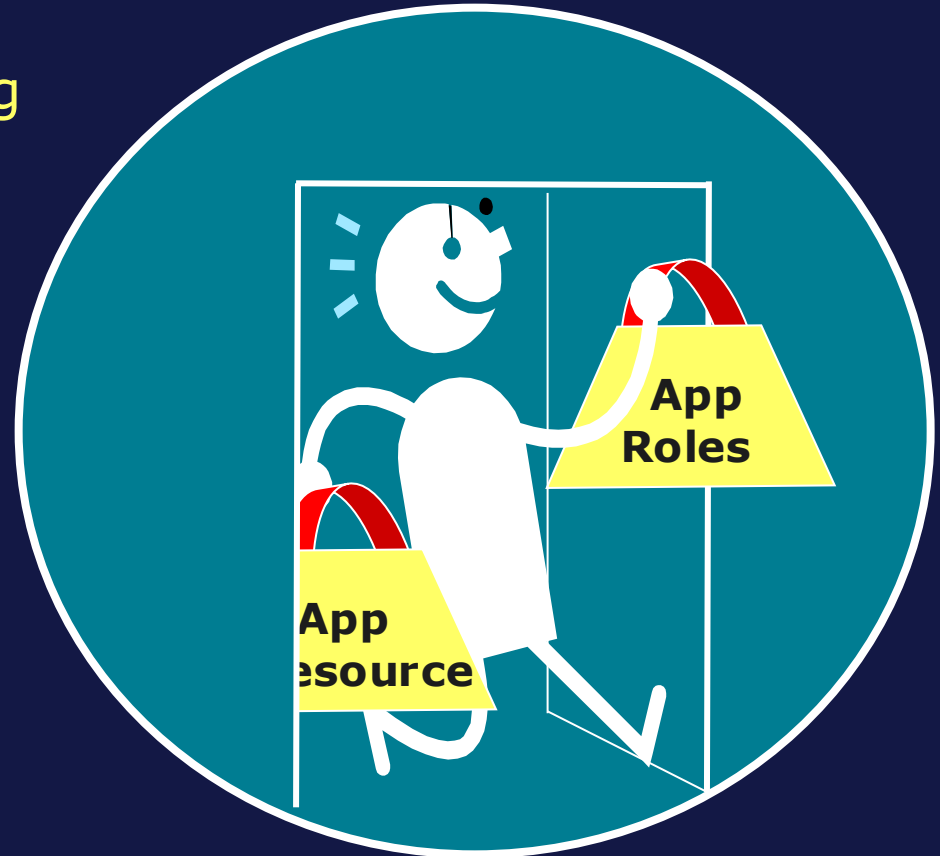
- Specify resource needed to access application.
 - Without appropriate resource, no application access allowed.



Common Capabilities (cont.)

- Role escalation.
 - Add roles to user accessing application.
 - Is in addition to existing roles.

Application



Resource Specification

- Specify resource needed to access application.

Resource Required

Application resource
needs to be defined first.



Web Application Specifics

- Can also specify authentication allowed for specific web application.

Resource Required			Group By ID			
Allowed Authentication Methods	☒ Unauthenticated	☒ Password	☐ Kerberos	☐ Two-factor Time-based One-time Password	☐ Two-factor SMS	☐ Login Cookie
Permitted Classes						



Demo

- Test authentication method for Management Portal.
- Look at csp/sys/op web application definition.



Application Definition Usage

- Common capabilities:
 - Role escalation.
 - Allows user to have limited or no privileges outside of application.
 - Resource restriction.
 - Restrict application use to those with required resource.
- Web Application definition.
 - Limit authentication methods for application.
- Privileged Routine definition.
 - Allows code to execute AddRoles() method.



Suggested Readings

- *Authorization Guide.*
 - *Applications.*



Authorization: Putting It All Together



Overview

- Protecting:
 - Access.
 - System.
 - Data.
 - Applications.



Protecting Access

- How do you protect the following from unauthorized access?
 - System.
 - Data.
 - Applications.
 - Functionality within applications.



Protecting System

- Services

- Enable/disable.
- Service resource required for non-public services.
- Multiple authentication mechanisms.
- Client System Security.

- Users

- Username/password for each user.
- Application users may require no privileges, if role escalation is used.
 - System access only via application.



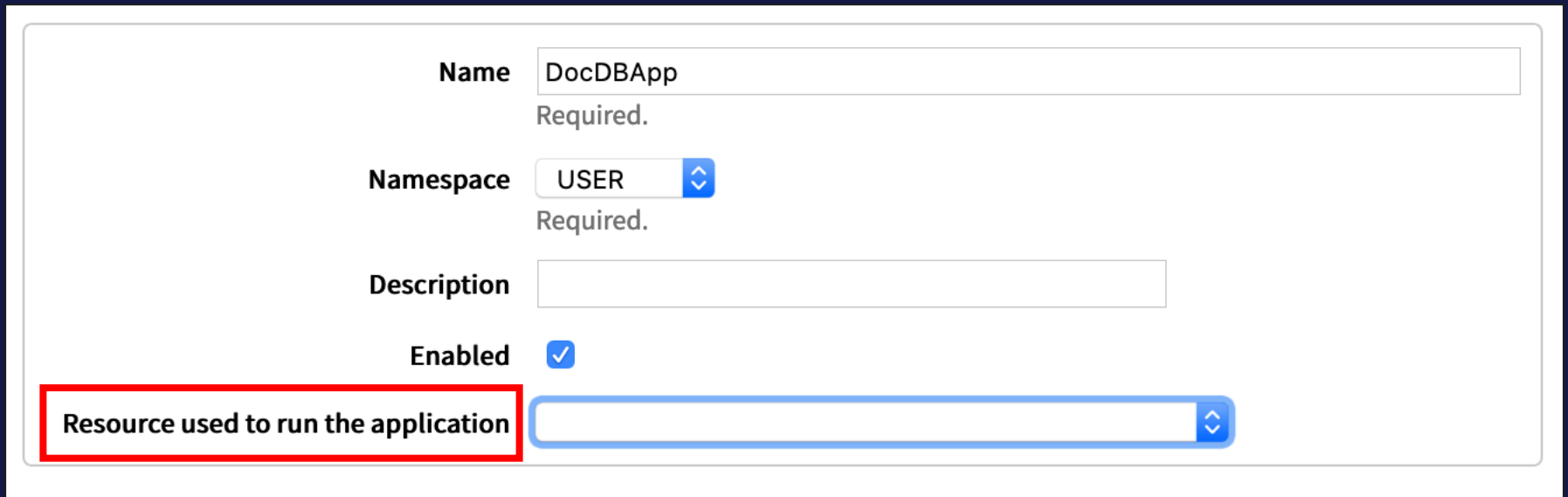
Protecting Data

- DB resources.
 - Define Read, Write or no access.
- Role escalation for applications.
 - Permits application users to have no or few roles.
- AddRoles() requires Privileged Routine Application definition.
 - Prevent unauthorized code from adding roles which result in unauthorized privileges.
- Command line access requires %Development resource.



Protecting Applications

- Application definitions.
 - Can require specific resource to access application.



The screenshot shows a form for defining an application. It includes the following fields and controls:

- Name:** A text input field containing "DocDBApp". Below it, the text "Required." is displayed.
- Namespace:** A dropdown menu showing "USER". Below it, the text "Required." is displayed.
- Description:** An empty text input field.
- Enabled:** A checkbox that is checked, indicated by a blue checkmark icon.
- Resource used to run the application:** This label and its corresponding dropdown menu are highlighted with a red rectangular border. The dropdown menu is currently empty.



Suggested Readings

- *Authentication Guide.*
 - *Services.*
- *Authorization Guide.*
 - *Assets and Resources.*
 - *Privileges and Permissions.*
 - *Roles.*
 - *User Accounts.*



Sync Security Data



Export/Import Security Settings

- %SYS>do ^SECURITY
 - Option 12: System parameter setup.
- Use methods of Security.System class.
 - ExportAll().
 - ImportAll().
- Save backup copy of settings.

```
Export to file name SecurityExport.xml =>  
Parameters? "WNS" =>  
Confirm export of selected security records to  
  
Exported 24 Application security records  
Exported 1 Domain security records  
Exported 25 Event security records  
Exported 32 Resource security records  
Exported 19 Role security records  
Exported 0 SSLConfig security records  
Exported 16 Service security records  
Exported 1 System security records  
Exported 23 User security records  
  
Export complete
```



^SECURITY Routine

- Comparable functionality in Management Portal.
- Requires %Admin_Secure:Use to run.

```
%SYS>do ^SECURITY

1) User setup
2) Role setup
3) Service setup
4) Resource setup
5) Application setup
6) Auditing setup
8) SSL configuration setup
9) Mobile phone service provider setup
10) OpenAM Identity Services setup
11) Encryption key setup
12) System parameter setup
13) X509 User setup
14) Exit

Option? █
```



Emergency Access



Emergency Access

- Windows:

`iris start InstanceName /EmergencyId=UserName,Password`

- UNIX® and Linux:

`iris start InstanceName EmergencyId=UserName,Password`

- Must be logged into OS as privileged OS account.

- Windows – user with local admin rights.

- Run Command Prompt as administrator.

- UNIX® and Linux– use sudo.

- Username need not exist in system or OS.



Emergency Access (cont.)

- Used for:
 - Fixing severe corruption to security configuration information.
 - Allowing only one user on system to perform maintenance, troubleshoot or restore a backup.



Emergency Access Behavior

- Specified user has %All privileges.
 - Similar to “super user”.
 - Only user that may log in.
- Console, Terminal and Web Gateway are only ways to access system.
 - All Management Portal functionality available for Normal and Locked Down installations.
- Auditing enabled, if possible.
- Configuration changes not effective until next restart.



Additional Emergency Access Behavior

- Not started:
 - Task Manager.
 - Mirroring.
- Not run:
 - %ZSTART and %ZSTOP.
- No 2FA

